

Midterm Project: Cybersecurity Plan for an AI-Integrated IIoT System

Chad Jones

Houston Community College (HCC)

A.I. at the Edge & IIOT Env

Prof. Sitaram Ayyagari

April 4, 2026.

Midterm Project: Cybersecurity Plan for an AI-Integrated IIoT System

System Design and Vulnerability Identification:

Smart Factory: AI-Driven Predictive Maintenance & Quality Control System

The chosen system is a large-scale smart manufacturing facility that deploys AI-powered predictive maintenance alongside an automated visual quality inspection pipeline. The plant integrates thousands of IIoT sensors embedded in production equipment (CNC machines, robotic arms, conveyor belts, and HVAC systems) with machine learning inference engines that run at the edge and in a private cloud. The result is a cyber-physical system where data-driven decisions directly control physical actuators on the shop floor — making cybersecurity a safety-critical concern.

System Components

Component	Quantity (est.)	Function
Vibration / Temperature Sensors	4,000+	Monitor rotating machinery for anomalies
Industrial Cameras (Vision)	120	Visual quality inspection on production lines
Programmable Logic Controllers (PLCs)	80	Control actuators; bridge OT and IT networks
Robotic Arms (AI-guided)	35	Precision assembly, welding, material handling

Component	Quantity (est.)	Function
Edge AI Inference Nodes (GPU)	20	Run ML inference <5 ms latency at the edge
SCADA Workstations	6	Operator HMI, alarm management, historian
Network Switches / Routers	45	Industrial Ethernet, OPC-UA, MQTT routing

AI Models

- Predictive Maintenance Model (LSTM / GRU) — trained on 18 months of sensor telemetry; predicts component failure 72 hours in advance.
- Visual Defect Detection Model (CNN / YOLO v8) — classifies product defects in real time at 30 fps on edge GPUs.
- Anomaly Detection Model (Isolation Forest) — flags unusual network or process-level behavior for the SOC team.
- Digital Twin Simulation Engine — real-time physics-based model of the plant used by the AI for counterfactual reasoning.

Network Infrastructure

- Zone 1 — OT Network (PROFINET, OPC-UA): PLCs, sensors, actuators.

- Zone 2 — Edge AI Network (TSN Ethernet): Edge inference nodes, cameras.
- Zone 3 — IT / Enterprise Network (TCP/IP): ERP, MES, historian, cloud connector.
- Zone 4 — Cloud (Private Azure / AWS): ML training pipeline, digital twin, remote monitoring.
- DMZ: Purdue Model-based industrial DMZ separating OT from IT.

Data Flow Diagram (Narrative)

Data Flow Summary

Sensors → (MQTT over TLS) → Edge Nodes → (OPC-UA over TLS) → SCADA/Historian → (Encrypted REST API) → Cloud ML Pipeline → (Signed inference results pushed back) → Edge Nodes → (OPC-UA) → PLCs / Actuators. Operator terminals connect to SCADA via VPN with MFA.

Vulnerability Assessment

A comprehensive threat modeling exercise was conducted using the STRIDE methodology (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) combined with ICS-CERT advisories and MITRE ATT&CK for ICS. The table below catalogues identified vulnerabilities by layer.

ID	Layer	Vulnerability	Exploitation Method	Severity
V-01	Device	Default Credentials on PLCs	Attacker uses manufacturer default username/password (e.g., admin/admin) to gain engineering-level access to PLC logic, allowing reprogramming of actuators.	CRITICAL
V-02	Device	Unpatched Firmware	Exploit known CVEs in unpatched sensor/PLC firmware via network-adjacent attack to achieve remote code execution (e.g., Triton/TRISIS-style).	HIGH
V-03	Device	Insecure Debug Ports (JTAG/UART)	Physical access to exposed debug interfaces on edge GPU nodes allows firmware extraction, memory analysis, and privilege escalation without authentication.	HIGH
V-04	Network	Flat OT/IT Network Topology	Absence of proper segmentation allows lateral movement from a compromised IT workstation into the OT network, enabling attacker to reach SCADA and PLCs.	CRITICAL
V-05	Network	Unencrypted OPC-UA Traffic	Man-in-the-middle attack captures and replays or tampers with OPC-UA sensor data, causing AI models to make incorrect actuation decisions.	HIGH
V-06	Network	Rogue Wireless Access Point	Attacker plants a rogue AP near the factory floor to capture factory WLAN traffic or inject malicious packets into edge node communications.	MEDIUM

ID	Layer	Vulnerability	Exploitation Method	Severity
V-07	Data	Unencrypted Historian Database	SQL injection or direct database access to the unencrypted sensor historian exposes proprietary process parameters, trade secrets, and production schedules.	HIGH
V-08	Data	Insufficient Data Integrity Checks	Tampered sensor readings injected into the data pipeline corrupt ML training datasets, causing model drift and unreliable predictive maintenance outputs.	HIGH
V-09	Application	SCADA HMI Web Vulnerabilities	Cross-site scripting (XSS) or CSRF in the SCADA web interface allows attackers to hijack operator sessions, alter displayed data, or issue unauthorized commands.	CRITICAL
V-10	Application	Insecure ML Model API	Unauthenticated REST endpoint for ML inference results accepts crafted inputs, enabling adversarial injection attacks that cause the model to mis-classify defects.	HIGH
V-11	AI Model	Adversarial Input Attacks	Subtle pixel-level perturbations to camera inputs fool the CNN defect detection model into approving defective products (adversarial example attack).	HIGH
V-12	AI Model	Model Poisoning (Training Data)	Insider or supply-chain attacker injects mislabeled training samples, causing the LSTM predictive maintenance model to fail silently on real failures.	CRITICAL

ID	Layer	Vulnerability	Exploitation Method	Severity
V-13	AI Model	Model Extraction / Inversion	Repeated API queries allow an attacker to reconstruct the proprietary ML model (model stealing) or infer sensitive production data from model outputs (inversion).	MEDIUM
V-14	Human	Phishing / Social Engineering	Spear-phishing email targeting SCADA operators delivers malware that establishes a C2 channel into the enterprise network, pivoting to OT systems.	HIGH
V-15	Human	Insider Threat	Disgruntled maintenance engineer with PLC programming credentials deliberately modifies ladder logic to cause equipment damage or production sabotage.	CRITICAL

Vulnerability Summary

Critical: 5 vulnerabilities | High: 7 vulnerabilities | Medium: 3 vulnerabilities | Total Identified: 15

Defense Strategy Development:

Defense Principles & Framework

The defense strategy is grounded in three overarching principles applied across all layers:

Defense-in-Depth (multiple overlapping security controls), Zero Trust Architecture (verify every request, assume breach), and Secure by Design (security integrated from the earliest engineering stage, not bolted on). The strategy maps to IEC 62443 (Industrial Cybersecurity), NIST CSF 2.0, and MITRE ATT&CK for ICS.

Defense Measures by Vulnerability

Vuln. ID	Defense Measure	Responsible Owner	Timeline
V-01	Mandatory credential rotation on all PLCs; centralized privileged access management (PAM) with CyberArk; SSH key-based authentication only.	OT Security Engineer	Week 1
V-02	Automated firmware inventory with SBOM (Software Bill of Materials); biweekly patch cycles; vendor vulnerability subscription feeds.	Patch Management Team	Week 2
V-03	Epoxy fill or metal plate cover all JTAG/UART ports on deployed nodes; tamper-evident seals; physical security audit quarterly.	Facilities / HW Security	Week 1
V-04	Implement full Purdue Model segmentation with industrial firewalls (Fortinet FortiGate NGFW); unidirectional security gateways (data diodes) between OT and IT.	Network Architect	Week 3
V-05	Enforce OPC-UA Security Mode = SignAndEncrypt (AES-256) on all endpoints; TLS 1.3 for MQTT; deploy certificate lifecycle management.	OT Network Engineer	Week 2
V-06	802.1X port-based NAC on all wired/wireless ports; RF monitoring with rogue AP detection (Cisco Catalyst Center); disable unused switch ports.	Network Security	Week 2

Vuln. ID	Defense Measure	Responsible Owner	Timeline
V-07	Encrypt historian database at rest (AES-256); TDE on SQL Server; restrict database access via role-based service accounts; disable direct SQL access.	Database Administrator	Week 1
V-08	Cryptographic data signing at sensor level (HMAC-SHA-256); blockchain-anchored audit trail for ML training data; anomaly detection on incoming sensor streams.	Data Engineer / AI Team	Week 3
V-09	Web Application Firewall (WAF) in front of SCADA HMI; OWASP Top 10 remediation; Content Security Policy headers; mandatory MFA for all HMI logins.	AppSec Engineer	Week 2
V-10	Mutual TLS (mTLS) authentication on all ML API endpoints; API gateway with rate limiting and input validation; signed JWT tokens for inference requests.	MLOps / AppSec	Week 2
V-11	Adversarial training with FGSM/PGD-augmented datasets; input preprocessing pipeline with JPEG compression and spatial smoothing; confidence threshold gating (reject low-confidence predictions).	AI/ML Security Team	Week 4
V-12	Federated learning with differential privacy; data provenance tracking; anomaly detection on training label distributions; human-in-the-loop review for boundary cases.	AI/ML Security Team	Week 4

Vuln. ID	Defense Measure	Responsible Owner	Timeline
V-13	Implement output perturbation / prediction API rate limiting; watermark model outputs; monitor for systematic query patterns indicative of model extraction.	MLOps Engineer	Week 3
V-14	Security awareness training (monthly phishing simulations); email gateway with sandboxed attachment analysis (Proofpoint); DNS filtering; endpoint EDR deployment.	Security Awareness / SOC	Week 1
V-15	Principle of Least Privilege enforced via RBAC on all PLC programming software; dual-person integrity (DPI) for critical PLC changes; User Behavior Analytics (UBA) monitoring.	HR + OT Security	Week 2

Layered Defense Architecture:

Secure by Design Principles

- Threat modeling (STRIDE + PASTA) integrated into design reviews before procurement.
- Security requirements documented in engineering specifications (per IEC 62443-2-4).
- Hardware security modules (HSMs) used for key storage on all edge nodes.
- Immutable infrastructure: edge nodes boot from verified, signed OS images (Secure Boot + TPM 2.0).

Authentication & Access Control

- Zero-trust identity: every user, device, and service must authenticate and be authorized for each resource request.
- Multi-factor authentication (MFA) mandatory for all privileged access (SCADA, historian, cloud console).
- Privileged Access Workstations (PAW) for OT engineers; jump servers for remote access.
- Role-Based Access Control (RBAC) with separation of duties: operators, engineers, and administrators have distinct, non-overlapping permissions.
- Automated account de-provisioning within 4 hours of employment termination.

Encryption & Data Protection

- Data in transit: TLS 1.3 minimum on all IT links; OPC-UA SignAndEncrypt on all OT links; IPSec VPN for cloud connectivity.
- Data at rest: AES-256-GCM for historian, AI model weights, and cloud storage; key rotation every 90 days.
- Data integrity: HMAC-SHA-256 signatures on all sensor telemetry payloads; rejected if signature fails validation.
- Backup encryption: daily encrypted backups with offline cold-storage copies (3-2-1 rule).

Network Security

- Industrial DMZ with Next-Generation Firewalls enforcing allowlisting (only approved protocols/ports/IPs).

- Micro-segmentation within OT zones; VLANs per production line with inter-VLAN ACLs.
- Intrusion Detection System (IDS) tuned for ICS protocols (Claroty / Dragos platform).
- Network Traffic Analysis (NTA) to baseline normal behavior and alert on deviations.
- Out-of-band network management to prevent lateral movement through management plane.

Secure Software Development

- SDLC security gates: SAST (Checkmarx), DAST (OWASP ZAP), and SCA (Snyk) in the CI/CD pipeline.
- Dependency management: all open-source libraries reviewed against CVE databases before approval.
- Container image signing (Notary v2) for ML model containers deployed to edge nodes.
- Secure code review checklist applied to all SCADA HMI and ML API code changes.

Physical Security

- Server rooms and PLC cabinets: biometric access + PIN; CCTV monitoring; tamper alarms.
- Visitor escort policy: no unescorted vendor access to OT areas.
- Hardware inventory management: asset tags, RFID tracking, and quarterly physical audits.

Security Monitoring & Incident Response

- 24/7 SOC with industrial-aware SIEM (Splunk + Dragos integration); 15-minute MTTD target.
- ICS-specific IR playbooks for scenarios: ransomware, AI model poisoning, PLC manipulation, insider threat.
- Annual tabletop exercises simulating a full plant-wide cyberattack scenario.
- CISA ICS-CERT relationship established for threat intelligence sharing.
- Recovery Time Objective (RTO): 4 hours for critical OT systems; Recovery Point Objective (RPO): 1 hour.

AI-Specific Security Measures

- Adversarial Robustness Toolbox (ART) integrated into ML training pipeline for automated robustness testing.
- Model cards and datasheets published internally with known limitations documented.
- Continuous model performance monitoring: drift detection triggers re-evaluation and potential rollback.
- Human-in-the-loop override: operators can always manually override AI actuation decisions.
- Federated learning with differential privacy (epsilon = 1.0) for cross-plant model improvements without exposing raw data.
- Model signing: all deployed inference models carry a cryptographic signature verified at load time.

Implementation Roadmap

Phase	Activities	Key Technologies	Duration
Phase 1: Foundations	Asset inventory, SBOM generation, default credential remediation (V-01, V-03), physical security audit, security awareness kickoff (V-14), historian encryption (V-07)	CyberArk, Tenable.ot, Splunk	Weeks 1–2
Phase 2: Network Hardening	OT segmentation (V-04), OPC-UA encryption (V-05), NAC/rogue AP (V-06), WAF deployment (V-09), mTLS on ML APIs (V-10), PAM rollout	Fortinet NGFW, Claroty, Cisco ISE	Weeks 3–4
Phase 3: Data & AI Security	Data signing pipeline (V-08), model API rate limiting (V-13), adversarial training (V-11), poisoning defenses (V-12), UBA for insiders (V-15)	ART, MLflow, Apache Kafka	Weeks 5–8
Phase 4: Monitoring & IR	SIEM tuning, ICS-specific detection rules, IR playbook authoring and tabletop exercise, continuous vulnerability scanning	Splunk, Dragos, Tenable	Weeks 9–12
Phase 5: Continuous Improvement	Quarterly pen tests, red team exercises, model drift monitoring, patch cadence review, CISA threat intel integration	All platforms + CISA feeds	Ongoing

Penetration Testing Simulation

Methodology & Scope

Penetration testing simulations were conducted using a red team / blue team structure, following the PTES (Penetration Testing Execution Standard) methodology adapted for ICS environments. Scope was limited to the simulated environment to avoid any disruption to real systems. Tools

used included Kali Linux, Metasploit Framework, Shodan queries (passive recon only), Wireshark, CrackMapExec, Ettercap (ARP spoofing), CleverHans (adversarial ML), and custom Python scripts.

Simulation Scenarios & Results

Scenario	Attack Technique	Finding	Defense Rating
S1: Credential Attack	Default PLC credential brute force using Hydra against Siemens S7 PLC simulator	Default credentials changed; PAM blocked 3rd failed attempt and alerted SOC within 90 seconds. Attack unsuccessful.	Pass
S2: Network Pivot	Compromise IT workstation via phishing email; attempt lateral movement to OT VLAN	Phishing email blocked by Proofpoint. Simulated breach: firewall ACLs prevented pivot to OT VLAN. OT completely isolated.	Pass
S3: MitM on OPC-UA	ARP spoofing + Ettercap to intercept OPC-UA traffic between PLC and edge node	All OPC-UA traffic encrypted (SignAndEncrypt); captured traffic unreadable. Certificate pinning prevented certificate substitution.	Pass
S4: SCADA HMI XSS	Inject XSS payload via historian search field to steal operator session token	WAF blocked the XSS payload. CSP headers prevented script execution. Partial: one legacy HMI page lacked WAF coverage.	Partial
S5: Adversarial Camera Input	FGSM adversarial perturbation applied to camera image to fool defect detection CNN	Standard model misclassified 4/10 adversarial images. Post-adversarial-training model misclassified 1/10. Improvement significant but not perfect.	Partial

Scenario	Attack Technique	Finding	Defense Rating
S6: Insider PLC Modification	Authorized maintenance engineer (red team) attempts to upload modified PLC ladder logic	DPI (dual-person integrity) policy triggered; second engineer approval required. UBA flagged the after-hours access. Modification blocked.	Pass
S7: ML API Abuse	Automated script sends 50,000 inference queries to extract model behavior	API gateway rate limiter triggered at 1,000 requests/hour; IP blocked after threshold. Query pattern logged and alerted.	Pass
S8: Ransomware Simulation	Simulate ransomware propagation from IT network attempting to reach historian	Network segmentation contained spread to IT VLAN. OT unaffected. Historian backup restored in 47 minutes (within 1-hour RPO).	Pass

Identified Weaknesses & Proposed Improvements

Weakness: Partial SCADA WAF Coverage (S4)

Finding

One legacy SCADA HMI page (the historian search interface) was not routed through the WAF, leaving it vulnerable to XSS injection.

Proposed Improvement: Conduct a complete application inventory of all SCADA web interfaces. Ensure ALL pages are behind the WAF with no bypass routes. Implement a quarterly application security scan using OWASP ZAP as a CI/CD gate for HMI software updates. Estimated remediation time: 1 week.

Weakness: Residual Adversarial ML Vulnerability (S5)**Finding**

Even after adversarial training, 1 in 10 adversarial examples still bypassed the CNN defect detection model. In a high-throughput production environment this could result in defective products escaping quality control.

Proposed Improvement: Implement a multi-model ensemble approach (majority voting across 3 independently trained models with different architectures) to reduce single-model vulnerability. Add a secondary rule-based inspector as a safety backstop. Integrate certified defenses such as Randomized Smoothing to provide provable robustness bounds. Conduct quarterly adversarial red-team evaluations against the deployed model.

Positive Findings

- Network segmentation was the most effective single control — it contained every lateral movement attempt and limited blast radius significantly.
- MFA + PAM combination proved highly effective against credential-based attacks, with zero successful compromises.
- The dual-person integrity policy for PLC changes was a critical deterrent against insider threats.
- Incident response playbooks performed well: mean time to detect (MTTD) was 8.5 minutes on average; mean time to respond (MTTR) was 34 minutes.

Final Report & Reflections

Executive Summary

This midterm project designed and stress-tested a comprehensive cybersecurity plan for an AI-integrated IIoT smart factory system. Fifteen distinct vulnerabilities were identified spanning device, network, data, application, AI model, and human layers. A layered defense strategy grounded in Zero Trust, Defense-in-Depth, and Secure by Design principles was developed and mapped to an implementation roadmap. Penetration testing simulations validated the effectiveness of most controls, with two areas requiring remediation identified and addressed. The project demonstrates that securing AI-integrated IIoT environments requires a holistic approach — technical controls alone are insufficient without robust human and process safeguards.

Key Findings Summary

Category	Key Finding
Greatest Risk	Flat OT/IT network topology (V-04) and default credentials (V-01) posed the highest combined risk of catastrophic physical impact.
Most Effective Defense	Network segmentation (Purdue Model + NGFW) contained every lateral movement attempt in penetration testing.
AI-Specific Risk	Model poisoning (V-12) is the hardest vulnerability to detect; differential privacy and data provenance tracking are essential mitigations.
Human Factor	Phishing and insider threats remain the most likely initial attack vectors; technical controls

Category	Key Finding
	must be complemented by culture and process.
Residual Risk	Adversarial ML attacks on vision models remain partially effective; multi-model ensembles and certified defenses are recommended next steps.

Proposed Future Improvements

1. Implement a formal IEC 62443 certification audit with an accredited third party to validate all security controls against the international standard.
2. Explore homomorphic encryption for cloud-based ML inference to enable computation on encrypted sensor data without decryption, eliminating a significant data exposure window.
3. Develop a formal Supply Chain Risk Management (SCRM) program covering all IIoT hardware and software vendors, including SBOM requirements in procurement contracts.
4. Expand the adversarial robustness program to include physical adversarial attacks (e.g., adversarial stickers on physical products that confuse the vision model).
5. Deploy a formal Security Operations Center (SOC) with dedicated ICS analysts and integrate with CISA's Automated Indicator Sharing (AIS) for real-time threat intelligence.
6. Conduct annual third-party red team exercises specifically targeting the AI supply chain (model provenance, training data integrity, and inference API security).

Conclusion

The convergence of AI and IIoT in industrial settings creates immense operational value but simultaneously expands the attack surface in ways that traditional OT security frameworks were never designed to address. AI models are not just passive tools — they are active decision-making agents that control physical systems, making their security as critical as the network and devices they operate within. This project demonstrated that no single security control is sufficient; the most resilient posture emerges from the combination of network segmentation, zero-trust access control, cryptographic data integrity, AI-specific robustness measures, and a security-conscious human culture. The cost of a breach in this environment is not merely data loss — it is physical damage, production downtime, and potential harm to personnel.

References

- International Electrotechnical Commission. (2018). IEC 62443: Industrial Automation and Control Systems Security. IEC.*
- National Institute of Standards and Technology. (2024). NIST Cybersecurity Framework 2.0. NIST.*
- MITRE Corporation. (2023). ATT&CK for Industrial Control Systems (ICS). MITRE ATT&CK.*
- Goodfellow, I., et al. (2015). Explaining and Harnessing Adversarial Examples. ICLR 2015.*
- Dragos Inc. (2024). ICS/OT Cybersecurity Year in Review. Dragos Platform Intelligence.*
- CISA. (2023). Cross-Sector Cybersecurity Performance Goals. Cybersecurity and Infrastructure Security Agency.*
- Papernot, N., et al. (2018). cleverhans v2.0.0: an adversarial machine learning library. arXiv:1610.00768.*